

CCCS 453 – Security Risk Management and Governance

MODULE 8

Assignment #5: Risk Assessment

Al Labade, Ayman

Overview

This report identifies and analyzes five major information security risks faced by Financial Info Quest (FIQ), a start-up company providing financial data and news via a web platform to investment firms in Canada and internationally. For each risk, the threat source, threat event, vulnerabilities, likelihood, impact, and recommended mitigating controls are documented in alignment with CCCS 453 Assignment 5 requirements.

Risk 1 – Compromise of Remote Desktop (RDP) Access

1. Brief description of the risk

FIQ lets employees connect to their office desktops using Remote Desktop Protocol (RDP) from anywhere, at any time. Because this RDP setup was done quickly by interns and there is no mention of VPN, MFA, or other protections, there is a serious risk that attackers could break into the internal network through RDP and take over the systems.

2. Threat source

- External attackers scanning the internet for exposed RDP services.
- Malware operators and ransomware groups that specialize in exploiting weak and unprotected RDP endpoints.
- Former employees or contractors who retain knowledge of RDP settings or credentials.

3. Threat event

- An attacker guesses, brute-forces, or uses stolen passwords to log in via RDP.
- An RDP vulnerability is exploited on an unpatched Windows server.
- Once logged in, the attacker installs malware or uses the session to move laterally inside the network.

4. Vulnerability and threat impact

Key vulnerabilities include default or weak RDP configuration (no VPN, no network-level authentication, no multi-factor authentication), RDP opened broadly to the internet, and configuration done by inexperienced interns without formal secure-configuration standard. Once an attacker gains RDP access, they can function as a legitimate user with full access to internal resources, including the Oracle databases and payment systems, leading to data theft, fraud, service outages, and regulatory breaches.

5. Likelihood

Likelihood is High. RDP is one of the most commonly attacked remote-access services, and small start-ups that use interns and rush deployments are especially likely to misconfigure it.

6. Impact

Impact is High. Compromise of RDP can result in full internal compromise, data breaches, and long downtime. It could directly affect all clients who rely on FIQ's platform and payments.

7. Practical recommendations

- Do not expose RDP directly to the internet; require VPN or a secure remote-access gateway first.
- Enforce strong password policies and enable multi-factor authentication on all remote access.
- Restrict which IP ranges can connect via RDP and apply least privilege to RDP users.
- Keep Windows servers fully patched and enable Network Level Authentication (NLA).
- Monitor and log all remote access attempts, alert on repeated failures or unusual login times.
- Immediately disable or remove RDP accounts for employees and interns who leave.

Risk 2 – Insecure Custom Payment Processing and Credit Card Data

1. Brief description of the risk

Gino wants the same students to quickly build software so FIQ can charge clients' credit cards directly and avoid paying a third-party processor. This creates an elevated risk that cardholder data will be handled in an insecure manner, since the interns are likely to have no PCI-DSS or payment security experience.

2. Threat source

- External attackers focusing on web payment and databases that store card data.
- Malicious insiders with access to payment servers or databases.
- Malware on servers or analyst workstations capturing credit card details.

3. Threat event

- Exploiting vulnerabilities (SQL injection) in the custom payment application to dump credit card data.
- Intercepting unencrypted or poorly protected payment traffic between clients and FIQ.
- Unauthorized access to database or logs where full primary account numbers (PAN), CVV codes, or other sensitive authentication data are stored.

4. Vulnerability and threat impact

Vulnerabilities arise from lack of payment security expertise, absence of PCI-DSS aligned controls, insecure coding by interns, and the temptation to store full card numbers and other sensitive fields for "convenience" in recurring billing. A breach of cardholder data would impact hundreds of client organizations, lead to fraud losses, mandatory incident notification, forensic investigations, fines from card brands, and a significant loss of trust in FIQ's services.

5. Likelihood

Likelihood is High. Custom payment systems developed quickly by non-specialists are historically prone to severe security weaknesses, and start-ups often underinvest in compliance controls during early growth phases.

6. Impact

Impact is Very High. Compromise of cardholder data can lead to direct financial fraud, legal liability, regulatory penalties, the need to reissue cards, and long-term reputational damage that threatens the viability of the business.

7. Practical recommendations

- Use a reputable third-party payment gateway that tokenizes card data and keeps most cardholder data off FIQ's systems.
- If in-house processing cannot be avoided, adopt PCI-DSS requirements: encrypt card data in transit and at rest, never store CVV, restrict access, and segment cardholder data environments.
- Introduce a secure SDLC: code reviews, secure-coding standards, and regular security testing (SAST/DAST, penetration tests).
- Keep only the minimum data needed (for example, tokens instead of full PANs) and enforce data-retention and secure-deletion policies.
- Log all access to payment systems and regularly review the logs for suspicious activity.

Risk 3 - Vulnerable Client-Facing Web Application

1. Brief description of the risk

FIQ's main web platform (public and members-only) was built by three graduate students during a summer, using Java on Windows with Oracle databases. Without proper secure-coding practices and testing, the application is likely to contain common web vulnerabilities that attackers can exploit.

2. Threat source

- External attackers scanning and attacking financial web applications.
- Malicious competitors seeking to steal data or disrupt services.
- Authenticated but malicious or compromised client accounts abusing application logic.

3. Threat event

- SQL injection or other injection attacks against Java application, targeting the Oracle databases to read, modify, or delete records.
- Exploiting weak authentication or session management to hijack client sessions or escalate privileges.
- Cross-site scripting attacks to steal credentials or run malicious scripts in clients' browsers.

4. Vulnerability and threat impact

Vulnerabilities often stem from inexperienced student developers, lack of formal security requirements, absence of regular security testing, and potential weak password policy for client accounts. Successful exploitation could expose sensitive information, proprietary market analytics, and payment or credential data, leading to loss of confidentiality, service downtime, and damage to FIQ's reputation.

5. Likelihood

Likelihood is High. Internet-facing financial applications are high-value targets, and student-built code with no mention of security testing is likely to contain exploitable issues.

6. Impact

Impact is High. If the main platform is compromised, almost all clients are affected, service could be taken offline, and sensitive information could be leaked or altered.

7. Practical recommendations

- Establish secure-coding guidelines (for example, input validation, parameterized queries, output encoding) and enforce them through code review.
- Conduct regular vulnerability scans and web application penetration tests and fix high-risk findings quickly.
- Implement robust authentication and authorization controls, including strong password policies, optional multi-factor authentication for clients, and secure session management.
- Use web application firewalls (WAF) to detect and block common attack patterns.
- Ensure proper configuration and hardening of the Java application server and Oracle database (least privilege, strong accounts, patching).

Risk 4 – Physical Security of Server Room and Office Environment

1. Brief description of the risk

FIQ's servers, hosting the Java application and Oracle databases, are located in a private room within a rented floor in a newly renovated building in a neighborhood with high vacancy rates and low rental prices. Weak building and office-level physical security could allow unauthorized individuals to access or tamper with critical servers and networking equipment.

2. Threat source

- Opportunistic thieves taking advantage of lower security in a high-vacancy building.
- Resentful employees or contractors who already have access to the office.
- Unauthorized visitors or intruders tailgating into the office and reaching the server room.

3. Threat event

- Theft of servers, backup media, laptops, or smartphones from the office.
- Physical tampering with servers (for example, inserting USB devices, booting from external media, or installing hardware keyloggers).
- Damage to equipment due to vandalism or unsafe handling by unauthorized people.

4. Vulnerability and threat impact

Vulnerabilities may result from lack of strong building access controls, insufficient door locks or surveillance for the server room, unclear visitor management, and absence of documented physical-security procedures. Physical compromise can result in complete loss of systems and data, exposure of unencrypted data on drives, extended downtime, and inability to deliver services to clients.

5. Likelihood

Likelihood is Medium to High. The office is located in a low-cost high-vacancy area, which often correlates with weaker building security and higher risk of physical incidents compared to more secure, high-end office spaces.

6. Impact

Impact is High. Loss or compromise of production servers and databases can interrupt all client services, expose sensitive data, and require costly incident response and recovery efforts.

7. Practical recommendations

- Implementation of strong access controls to both the office and server room (badges, locked doors, access lists, and visitor escort policies).
- Installation of CCTV cameras covering entrances, exits, and the server room, and retain recordings for investigation if needed.
- Encrypt all server and laptop drives so that stolen hardware does not expose data.
- Use secure storage for laptops and smartphones when not in use and enforce a clean-desk policy.
- Coordinate with building management to assess and improve overall building security (lighting, guards, entry controls).

Risk 5 – Third-Party / Offshore News Monitoring Provider

1. Brief description of the risk

FIQ wants to sign a low-cost deal with an offshore company to provide 24/7 monitoring of online news. Depending on how this service is integrated, this third party might get access to FIQ's systems, data feeds, or credentials, which introduces vendor and data-sovereignty risks.

2. Threat source

- Malicious or careless staff at the offshore provider.
- External attackers targeting the provider's weaker security posture as an indirect path into FIQ's environment.
- Legal and jurisdictional issues linked to data handling across borders.

3. Threat event

- Unauthorized access to FIQ data or systems through accounts or interfaces given to the offshore provider.
- Leakage or misuse of proprietary or client-related information shared with the provider.
- Service disruption if the provider suffers a cyber incident and cannot deliver its monitoring services.

4. Vulnerability and threat impact

Vulnerabilities include a focus on low cost rather than verified security controls, absence of formal vendor-risk management, and lack of clear contractual requirements for information security, confidentiality, and incident reporting. A compromise at the provider could expose confidential business information, market-sensitive data, or client relationships, and could also serve as a pivot point into FIQ's environment if network trust is excessive.

5. Likelihood

Likelihood is Medium. While the provider may be legitimate, the strong focus on very low-cost offshore status suggests that security and legal aspects have not been fully assessed yet.

6. Impact

Impact is Medium to High. A third-party incident may not directly compromise every FIQ system, but it can still cause data leaks, service disruptions, reputational damage, and increased regulatory scrutiny regarding outsourcing and cross-border data transfers.

7. Practical recommendations

- Set up a basic vendor-risk management process: security questionnaires, reference checks, and, where possible, audits or independent security attestations.
- Include clear contractual security requirements (confidentiality, data-handling, encryption, incident notification, right to audit, subcontractor controls, and data-location requirements).
- Limit the provider's technical access to FIQ systems to the minimum required, with strong authentication, logging, and network segmentation.
- Regularly review the provider's performance security posture and keep a contingency plan in case FIQ needs to switch providers.